

Mapeo GQM+PRAGMATIC — Trazabilidad a Requisitos Normativos

20 Indicadores × Objetivos GQM × Marcos Normativos × Calidad PRAGMATIC

Versión 1.0 · Documento (d) del Kit GQM+PRAGMATIC CSCRM

Leyenda:  Mandatorio ·  Buena práctica ·  En vigor progresivo ·  Emergente

Tabla Maestra de Trazabilidad

ID	Indicador	Obj.	NIST CSF 2.0	SP 800-161r1	ENS 311/2022	NIS2 España	ISO 27001:2022	PRAGMATIC
M01	Tasa Incidentes CSCRMs	01	RS.MA-01 ✓	C-RS.MA-1 ✓	op.exp.7 ✓	Art. 23 ✓	5.26-5.27 ✓	63 ⚠
M02	MTTD-SC	01	DE.AE-04 ✓	C-DE.CM-9 ✓	op.exp.1 ✓	Art. 23 24h/72h ✓	9.1 📄	66 ✓
M03	Coste Medio Incidente	01	RS.MA-02 📄	—	op.exp.7 📄	Art. 23 📄	5.27 📄	57 ⚠
M04	Tasa Org. con Incidente	01	DE.AE-04 ✓	C-RS.MA-1 ✓	op.exp.1-7 ✓	Art. 23 ✓	5.26 📄	57 ⚠
M05	Política CSCRMs Formal	02	GV.SC-01 ✓	C-GV.SC-1 ✓	org.1 ✓	Art. 21.1 ✓	5.19 ✓	69 ✓
M06	Inventario Proveedores	02	ID.AM-05 ✓	C-ID.SC-2 ✓	op.ext.1 ✓	Art. 21.2.d ✓	5.19-8.4 ✓	69 ✓
M07	Distribución IGM	02	Todos GV.SC ✓	Todos C-GV.SC ✓	Múltiples ✓	Art. 21 ✓	9.1 ✓	69 ✓
M08	Due Diligence	02	GV.SC-06 ✓	C-GV.SC-6 ✓	op.ext.1 ✓	Art. 21.2.d ✓	5.19 ✓	69 ✓
M09	Brecha por Dominio	02	GV.SC completo ✓	Todos C-GV.SC ✓	Todos op.ext ✓	Art. 21 ✓	9.1-9.3 ✓	75 ✓
M10	Cobertura N-Tier	03	GV.SC-04 ✓	C-ID.SC-4 ✓	op.ext.1 ✓	Art. 21.2.d+22 ✓	8.4 ✓	60 ⚠
M11	Cobertura SBOM	03	GV.SC-05 → SOON	C-GV.SC-5 → SOON	op.mon.4 → SOON	CRA Art. 13 → SOON	8.8 → SOON	72 ✓
M12	Madurez PQC	03	GV.SC-05 → SOON	—	— → SOON	Roadmap CE PQC → SOON	8.24 → SOON	63 ⚠
M13	PRI con CS	04	GV.SC-08 ✓	C-RS.RP-1 ✓	op.exp.7 ✓	Art. 21.2.a ✓	5.26-5.28 ✓	69 ✓

M14	Plazos NIS2	04	RS.CO-04 ✓	C-RS.CO-4 ✓	op.exp.7 ✓	Art. 23 24h/72h /1m ✓	5.28 ✓	75 ✓
M15	Participación ISACs	04	GV.SC-10 📄	C-GV.SC-10 📄	—	Art. 29 📄	5.5-5.6 📄	63 ⚠️
M16	Ejercicios con Prov.	04	GV.SC-08 📄	C-GV.SC-8 📄	op.exp.7 📄	Art. 21.2.a 📄	5.26 📄	69 ✓
M17	Zero Trust Prov.	02+03	PR.AA-05 ✓	—	op.acc.1/4/5 ✓	Art. 21.2.i ✓	8.2-8.3 📄	66 ✓
M18	Cláusulas Contractuales	02	GV.SC-05 ✓	C-GV.SC-5 ✓	op.ext.1 ✓	Art. 21.4 ✓	5.20-5.21 ✓	75 ✓
M19	IA/ML Evaluados	03	GV.SC-04 ⚡	—	—	Reg. IA UE 2024/1689 ⚡	—	63 ⚠️
M20	Ciclo de Vida Prov.	02+03	GV.SC-10 ✓	C-GV.SC-10 ✓	op.ext.1 ✓	Art. 21.2.d ✓	5.19-5.23 ✓	78 ✓

Cobertura por Marco Normativo

Marco	Indicadores cubiertos	Obligatoriedad
NIST CSF 2.0	20/20 (100%)	Referencia en UE
NIST SP 800-161r1	16/20 (80%)	Referencia técnica máxima CSCRm
ENS RD 311/2022	17/20 (85%)	✓ Mandatorio sector público + proveedores
NIS2 / Anteproyecto Ley España	20/20 (100%)	✓ Mandatorio entidades esenciales e importantes
ISO/IEC 27001:2022	18/20 (90%)	📄 Voluntario / exigido contractualmente
INCIBE-CERT IMC v2.8	11/20 (55%)	📄 Marco de referencia nacional
CRA (UE 2024/2847)	2/20 (10%)	→ SOON Mandatorio progresivo 2025-2027
Roadmap PQC CE + NIST FIPS 203/204/205	2/20 (10%)	→ SOON Mandatorio progresivo 2026-2035

Normas Críticas por Objetivo GQM

O1 — Norma crítica: NIS2 Art. 23

Plazos: 24h alerta temprana · 72h notificación · 1 mes informe final.

Sanción por incumplimiento: hasta 10 M€ o 2% facturación global (entidades esenciales).

O2 — Norma crítica: NIST SP 800-161r1 (nov. 2024)

12 tareas C-GV.SC que cubren el ciclo completo de CSCRМ.

Guía más completa disponible a nivel global para gestión de riesgos en cadena de suministro.

O3 — Norma crítica: Cyber Resilience Act (CRA, UE 2024/2847)

Introduce por primera vez en la UE la obligación de SBOM para todos los productos con elementos digitales.

Aplicación progresiva: 2025-2027. Impacto estructural en cadenas de suministro de software.

O4 — Norma crítica: DORA (UE 2022/2554)

En vigor desde enero 2025 para el sector financiero.

TLPT obligatorio con proveedores TIC + registro de todos los proveedores TIC críticos.

Top 5 Indicadores con Mayor Densidad Normativa

#	Indicador	Marcos cubiertos	PRAGMATIC
1	M20 Ciclo de Vida	ENS + NIS2 + NIST CSF + SP 800-161r1 + ISO 27001 + IMC	78
2	M18 Cláusulas Contractuales	ENS + NIS2 Art.21.4 + NIST CSF + ISO 27001 + IMC	75
3	M06 Inventario Proveedores	Todos los marcos principales	69
4	M13 PRI con CS	ENS + NIS2 + NIST CSF + ISO 27001 + IMC	69
5	M07 IGM	Evaluación global simultánea de todos los marcos	69

© 2026 · Mapeo Normativo GQM+PRAGMATIC CSCRМ · Documento (d)

ENS RD 311/2022 · NIS2 UE 2022/2555 · NIST SP 800-161r1 nov.2024 · NIST CSF 2.0 feb.2024 · NIST SP 800-55v2 dic.2024 · ISO/IEC 27001:2022 · INCIBE-CERT IMC v2.8 · CRA UE 2024/2847 · NIST FIPS 203/204/205 ago.2024 · DORA UE 2022/2554